COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

# Security+ 2.5 · Mitigation Techniques

Mestre CyberSec · **Aula 2.5 — Mitigation Techniques** (6:51) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** Técnicas de mitigação em CAMADAS: patching (a base mais esquecida); encryption (proteção do dado); monitoring/EDR (observar + responder); least privilege (menor acesso); backup (recovery); training (treinar o humano); compensating control (quando o ideal não dá).

## 💡 Highlights que a prova CompTIA cobra

- Patching: a defesa básica mais esquecida (a maioria dos breach era patch conhecida)
- Least privilege: cada pessoa só o mínimo
- Defesa em camadas: nunca 1 solução — empilha

## 🎯 Dicas de Prova & Cenários Típicos da Banca

- 'reduces impact but doesn't eliminate vulnerability' = compensating control

## 🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.5 — Mitigation Techniques)

**Por que este aprofundamento é cobrado na prova?:** O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

**• Aplicação de Patches / Correção (N/A)**

Processo de atualizar software, firmware e sistemas operacionais para corrigir vulnerabilidades conhecidas; é uma mitigação fundamental e deve ser priorizada por risco e exposição.

⚠️ ***Armadilha CompTIA:*** *Se a questão mencionar 'known vulnerability explorada' ou 'breach por falta de atualização', a resposta provável é patching/patch management. Lembre: patch corrige a vulnerabilidade; compensating control apenas reduz o risco.*

**• Criptografia (N/A)**

Conversão de dados em texto cifrado ilegível para proteger a confidencialidade em repouso e em trânsito; reduz o impacto se os dados forem interceptados ou roubados.

⚠️ ***Armadilha CompTIA:*** *Criptografia protege confidencialidade/integridade, não disponibilidade nem impede malware. Se a questão fala de 'dados roubados mas inúteis', escolha encryption. Key management é o ponto crítico.*

**• Detecção e Resposta em Endpoints (EDR)**

Solução de segurança que monitora continuamente a atividade de endpoints, detecta comportamento suspeito e permite ações de resposta como isolamento ou remediação.

⚠️ ***Armadilha CompTIA:*** *EDR = monitorar + detectar + responder no endpoint; não é só antivírus. Se a questão pedir 'correlacionar logs de várias fontes', pense SIEM; se for 'isolar host infectado', pense EDR.*

**• Privilégio Mínimo (PoLP)**

Princípio de que usuários, aplicações e sistemas recebem apenas os direitos de acesso mínimos necessários para executar suas tarefas legítimas.

⚠️ ***Armadilha CompTIA:*** *Least privilege reduz superfície de ataque e blast radius. Distinga de 'need to know' (acesso à informação) e de 'separation of duties' (dividir funções críticas).*

**• Backup / Cópia de Segurança (N/A)**

Cópia de dados e configurações usada para restaurar disponibilidade e integridade após perda, corrupção ou ransomware; backups devem ser testados e protegidos.

⚠️ ***Armadilha CompTIA:*** *Se a questão pedir 'recuperar após ransomware' ou 'restaurar dados', escolha backup. Lembre da regra 3-2-1 e de backups offline/imutáveis para não serem criptografados.*

• **Treinamento de Conscientização em Segurança (SAT)**
Controle administrativo que educa os usuários a reconhecer e evitar ameaças como phishing, engenharia social e manuseio inseguro de dados.

⚠️ ***Armadilha CompTIA:*** *Humanos são o elo mais fraco; se a questão mencionar phishing, engenharia social ou erro do usuário, treinamento/conscientização é a mitigação. Não é controle técnico.*

---

• **Controle Compensatório (N/A)**
Salvaguarda alternativa usada quando o controle primário ou ideal não pode ser implementado; reduz risco/impacto, mas não elimina a vulnerabilidade subjacente.

⚠️ ***Armadilha CompTIA:*** *Gatilho clássico: 'reduces impact but doesn't eliminate the vulnerability' = compensating control. Não confunda com controle corretivo (corrige o problema) nem preventivo (impede).*

---

• **Defesa em Profundidade (DiD)**
Estratégia de segurança em camadas que combina múltiplos controles para que, se um falhar, outros ainda protejam o ativo; nenhuma mitigação isolada é suficiente.

⚠️ ***Armadilha CompTIA:*** *Se a questão sugerir 'layered mitigation', 'multiple controls' ou 'never rely on one solution', escolha defense in depth. É o conceito guarda-chuva da lição.*

## 🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

### 📌 Gestão Contínua de Patches (Patch Management)

🏠 **Analogia Intuitiva:** É como a manutenção preventiva da fuselagem de um avião. Se a fabricante descobre uma microfissura estrutural em uma peça, ela emite um boletim mandando trocar aquele parafuso imediatamente em todos os aviões da frota. Se a companhia aérea ignorar o aviso para economizar tempo, o avião pode sofrer uma despressurização catastrófica no próximo voo. O patch de segurança é a peça nova que conserta a falha de fabricação antes que um hacker a exploda.

🔍 **Causa Raiz / Por que foi criado:** Softwares corporativos são desenvolvidos sob pressão comercial e contêm vulnerabilidades inevitáveis. Assim que uma falha crítica (CVE) se torna pública, atacantes desenvolvem kits de exploração automática em questão de dias. Sem aplicação disciplinada de patches, a rede permanece aberta a invasões automatizadas.

🛡️ **Visão do Auditor de GRC:** Auditar a existência de uma Política Formal de Gestão de Patches com SLAs contratuais claros (ex: vulnerabilidades críticas corrigidas em até 14 dias); mensurar a taxa de cobertura de patches em 100% dos servidores e estações corporativas.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'most fundamental and effective security mitigation technique against known vulnerabilities and automated exploit kits'. Resposta: Patch Management / Regular Patching.

### 📌 EDR (Endpoint Detection and Response - Detecção no Ponto Final)

🏠 **Analogia Intuitiva:** O antivírus antigo é como o segurança da portaria com um álbum de fotos de bandidos procurados (assinatura estática). Se o bandido colocar uma peruca nova, o segurança deixa entrar. O EDR é como um detetive experiente com câmeras e escuta dentro de cada sala do edifício: ele não liga para a foto do rosto; ele observa o comportamento da pessoa: 'Por que aquele sujeito está tentando abrir o cofre com um maçarico às 3 da manhã?'. O EDR detecta a anomalia na hora, algema o suspeito e isola a sala.

🔍 **Causa Raiz / Por que foi criado:** Ataques avançados operam 'fileless' (sem gravar arquivos no disco, apenas na memória RAM), exploram ferramentas legítimas do Windows (Living off the Land) e usam malwares mutáveis que burlam assinaturas estáticas. O EDR coleta telemetria profunda e analisa comportamentos anômalos em tempo real.

🛡️ **Visão do Auditor de GRC:** Garantir que 100% dos ativos corporativos possuam agentes EDR instalados e reportando ativamente ao console de segurança; auditar regras de contenção automatizada e capacidades de investigação forense remota do SOC.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'endpoint security software that monitors host telemetry in real time, uses behavioral analysis to detect fileless zero-day threats, and provides remote containment'. Resposta: EDR (Endpoint Detection and Response).

### 📌 Isolamento de Hosts Infectados e Quarentena de Rede

🏠 **Analogia Intuitiva:** É o protocolo de quarentena biológica em um grande hospital. Se um paciente na enfermaria começa a apresentar tosse com sangue de uma doença altamente contagiosa, os médicos não esperam 3 dias de laudos laboratoriais: eles fecham a porta do quarto com trava de pressão negativa imediatamente, cortando a circulação de ar com os outros quartos. O paciente continua recebendo oxigênio e remédio dos médicos (o host ainda conversa com o console do EDR), mas não infecta nenhum outro leito do hospital.

🔍 **Causa Raiz / Por que foi criado:** Ransomwares e worms se propagam por movimentação lateral na rede interna em segundos após a infecção inicial. O isolamento lógico de rede interrompe instantaneamente toda a conectividade IP da máquina infectada com a rede local e a internet, mantendo aberto apenas o canal de comando e resposta do EDR para a equipe de perícia forense.

🛡️ **Visão do Auditor de GRC:** Auditar os Planos de Resposta a Incidentes (IRP) e testar em exercícios de simulação prática (Tabletop) a capacidade de isolamento remoto de estações de trabalho comprometidas sem causar interrupção total das ferramentas de telemetria.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho: 'immediate technical containment action an incident responder takes to stop active malware or ransomware from spreading laterally across the enterprise subnet'. Resposta: Host Isolation / Network Quarantine.

### 📌 Controles Compensatórios e Segmentação para Sistemas Legados

🏠 **Analogia Intuitiva:** Um aparelho de ressonância magnética de 3 milhões de reais em um hospital foi fabricado há 15 anos e só roda Windows XP. A fabricante faliu, o sistema não aceita antivírus moderno e o hospital não pode descartar o equipamento. O que fazer? Você constrói uma jaula de vidro blindada em volta dele: coloca a máquina em uma VLAN isolada e trancada, com um firewall dedicado na frente que só deixa passar as imagens médicas para um servidor intermediário e proíbe qualquer outro tráfego. Isso é um controle compensatório: uma medida alternativa que reduz o risco quando a solução ideal não é viável.

🔍 **Causa Raiz / Por que foi criado:** Sistemas operacionais legados (Windows 7, XP, sistemas industriais SCADA e dispositivos médicos) não recebem mais atualizações de segurança e quebram se forem modificados. Quando a correção direta (patch) não é possível, a organização aplica controles alternativos ao redor do ativo para mitigar a exposição ao risco.

🛡️ **Visão do Auditor de GRC:** Manter inventário atualizado de sistemas legados fora de suporte; registrar no Comitê de Riscos o Termo de Aceitação de Risco formal e auditar a eficácia dos controles compensatórios (regras estritas de firewall, segmentação de VLAN e monitoramento de tráfego dedicado).

> ⚠️ **Como cai na Prova CompTIA:** Gatilho: 'legacy system running an unsupported operating system cannot support modern security agents or patches; what security control should be implemented?'. Resposta: Compensating Control / Network Segmentation.

## ⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

| Cenário Típico de Exame / Situação Prática | Conceito Técnico & Resposta da Banca |
|---|---|
| Mitigação técnica primordial mais eficiente contra vulnerabilidades de software e kits de exploit conhecidos | **Gestão de Patches (Patch Management)** |
| Tecnologia de segurança em hosts que monitora comportamento e responde a ataques sem arquivos em tempo real | **EDR (Endpoint Detection and Response)** |
| Primeira ação de contenção técnica para conter a propagação de ransomware em uma estação de trabalho | **Isolamento de Host / Quarentena de Rede** |
| Medida alternativa adotada para proteger sistemas legados que não suportam patches ou novos antivírus | **Controle Compensatório (Compensating Control - Ex: Segmentação de Rede)** |
| Ambiente virtual seguro e isolado usado por analistas para executar e analisar malwares suspeitos | **Caixa de Areia (Sandbox)** |
| Estratégia holística que combina múltiplas camadas de mitigação técnica, administrativa e física | **Defesa em Profundidade (Defense in Depth)** |

## ✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

### QUESTÃO 1 · CENÁRIO DE EXAME

**Uma empresa de contabilidade de médio porte sofreu um surto de ransomware que criptografou arquivos em todas as estações de trabalho e em dois servidores de arquivos. A análise forense revelou que os atacantes exploraram uma vulnerabilidade crítica no concentrador VPN voltado para a internet da empresa, para a qual o fornecedor havia lançado um patch quatro meses antes. Qual técnica de mitigação, se realizada de forma consistente, teria mais provavelmente impedido a intrusão inicial?**

**A)** Implementar um programa disciplinado de gestão de vulnerabilidades e gestão de patches com ciclos de revisão mensais

**B)** Implantar assinaturas de sistema de prevenção de intrusão baseado em rede para todo malware conhecido

**C)** Tornar obrigatória a capacitação de conscientização em segurança focada em reconhecer e-mails de phishing

**D)** Aplicar controles de acesso de menor privilégio em todas as contas de usuário do domínio

### QUESTÃO 2 · CENÁRIO DE EXAME

**Um hospital regional armazena informações protegidas de saúde (PHI) em laptops usados por médicos em viagens. Após o roubo de um laptop do carro de um médico, a equipe de segurança deve garantir que o PHI no dispositivo não possa ser lido pelo ladrão, mesmo que o disco seja extraído e montado em outro computador. Qual técnica de mitigação atende diretamente a esse requisito de confidencialidade?**

**A)** Implementar criptografia de disco completo (FDE) usando AES-256 em todos os dispositivos endpoint

**B)** Aplicar acesso de menor privilégio por meio de controle de acesso baseado em funções no laptop

**C)** Configurar agentes de EDR para colocar em quarentena processos desconhecidos

**D)** Implantar gerenciamento de dispositivo móvel para apagar remotamente o laptop roubado

### QUESTÃO 3 · CENÁRIO DE EXAME

**Os controladores legados Windows 7 no chão de fábrica de uma empresa de manufatura não podem ser substituídos por pelo menos 18 meses devido a restrições operacionais. A equipe de segurança deve proteger esses sistemas mesmo que eles não recebam mais atualizações de segurança do fornecedor. Qual técnica de mitigação é mais apropriada nesta situação?**

**A)** Implementar um controle compensatório, como segmentação de rede e um IPS à frente dos sistemas legados

**B)** Desativar todas as contas de usuário nos controladores legados até a substituição

**C)** Instalar o agente de proteção de endpoint mais recente, mesmo sem suporte para Windows 7

**D)** Migrar imediatamente todos os dados dos controladores legados para uma plataforma SaaS em nuvem

### QUESTÃO 4 · CENÁRIO DE EXAME

**Um atacante comprometeu uma conta de administrador de domínio por meio de um ataque de credential stuffing e conseguiu acessar todos os sistemas e bancos de dados da organização, incluindo sistemas não relacionados à função do administrador. Qual princípio de mitigação, se implementado corretamente, teria limitado o escopo de acesso que a conta comprometida poderia alcançar?**

**A)** Aplicar o Princípio do Menor Privilégio com acesso baseado em funções e elevação administrativa just-in-time

**B)** Implantar criptografia de disco completo em todos os servidores de arquivos com dados sensíveis

**C)** Implementar um sistema automático de implantação de patches em toda a empresa

**D)** Configurar regras de geofencing na conta do administrador para restringir logins

**QUESTÃO 5 · CENÁRIO DE EXAME**

**Um ataque de ransomware criptografou os compartilhamentos de arquivos primários da empresa e, crucialmente, também criptografou o ponto de backup conectado porque o volume de backup estava mapeado como uma unidade de rede visível aos hosts comprometidos. A empresa perdeu acesso a 30 dias de dados operacionais. Qual técnica de mitigação deve ser reprojetada para evitar a recorrência dessa falha específica?**

**A)** Aplicar a regra de backup 3-2-1 com cópias imutáveis, air-gapped ou offline que não fiquem continuamente acessíveis

**B)** Implantar assinaturas adicionais de antivírus de endpoint específicas para famílias de ransomware

**C)** Migrar todos os compartilhamentos de arquivos para um sistema SaaS de gestão de documentos em nuvem

**D)** Treinar os usuários finais para identificar e-mails de phishing que entregam o ransomware

**QUESTÃO 6 · CENÁRIO DE EXAME**

**Os resultados da simulação de phishing de uma empresa de varejo mostram que 28% dos colaboradores ainda clicam em links embutidos em e-mails simulados de phishing, mesmo após a empresa implantar filtragem avançada no gateway de e-mail que captura 99,5% das mensagens maliciosas. O CISO quer uma mitigação que trate o risco humano residual. Qual técnica trata mais diretamente esse risco?**

**A)** Implementar um programa contínuo de capacitação de conscientização em segurança com campanhas simuladas de phishing e coaching just-in-time

**B)** Bloquear todos os e-mails externos no gateway de e-mail para eliminar vetores de phishing

**C)** Adquirir uma plataforma de detecção e resposta estendida (XDR) para telemetria de endpoint

**D)** Exigir que todos os colaboradores usem chaves de segurança de hardware para autenticação multifator

**QUESTÃO 7 · CENÁRIO DE EXAME**

**O centro de operações de segurança (SOC) de uma empresa de software detecta um processo suspeito em uma estação de trabalho de um desenvolvedor que está carregando scripts PowerShell não assinados a partir da memória, evadindo o antivírus legado. O malware se comunica com um servidor C2 externo. Qual tecnologia de mitigação é projetada especificamente para detectar e responder a esse tipo de ataque fileless, baseado em comportamento?**

**A)** Endpoint Detection and Response (EDR) com análises comportamentais e telemetria de processos

**B)** Criptografia de disco completo aplicada via BitLocker com vinculação a TPM

**C)** Um scanner de vulnerabilidades executando varreduras autenticadas semanais nas estações

**D)** Um firewall de rede com regras de inspeção stateful de pacotes

**QUESTÃO 8 · CENÁRIO DE EXAME**

**Uma organização quer aplicar múltiplas camadas de mitigação para que, se um controle falhar, outros continuem protegendo o ativo. O arquiteto projeta controles sobrepostos: firewalls de rede, EDR em endpoints, allowlisting de aplicações, backups criptografados, acesso de menor privilégio e treinamento de segurança. Qual princípio de segurança está sendo aplicado?**

**A)** Defesa em Profundidade (DiD) com controles em camadas e sobrepostos

**B)** Eliminação de ponto único de falha por meio de redundância

**C)** Zero Trust com verificação contínua

**D)** Princípio da menor funcionalidade aplicado aos sistemas

**QUESTÃO 9 · CENÁRIO DE EXAME**

**Um novo aplicativo SaaS usado pelo departamento de marketing armazena dados de cartão de crédito de clientes em seu banco de dados. O fornecedor ainda não oferece criptografia em nível de campo para essa coluna de dados. A equipe de segurança deve escolher uma mitigação para reduzir o risco de exposição caso o banco SaaS seja violado. Qual técnica trata diretamente da confidencialidade do dado em si, independente dos controles do fornecedor?**

**A)** Implementar criptografia na camada de aplicação dos dados do cartão antes de transmiti-los e armazená-los, usando chaves controladas pela organização

**B)** Aumentar a frequência dos questionários de avaliação de segurança do fornecedor

**C)** Exigir que o fornecedor altere senhas do banco de dados a cada 30 dias

**D)** Exigir que a equipe de marketing use VPN ao acessar o aplicativo SaaS

**QUESTÃO 10 · CENÁRIO DE EXAME**

**Após um incidente de Comprometimento de E-mail Corporativo (BEC), uma auditoria revela que os únicos controles da organização eram um filtro de spam básico e um firewall. Não havia EDR, MFA, verificação de backup, cadência formal de patches nem treinamento de conscientização. O CISO quer implementar uma estratégia abrangente de mitigação que contemple pessoas, processos e tecnologia. Qual combinação melhor representa um roadmap de mitigação em camadas alinhado à defesa em profundidade?**

**A)** Implantar MFA em todas as contas de e-mail, aplicar menor privilégio com caixas postais baseadas em função, habilitar EDR em endpoints, implementar backups imutáveis offline, executar um programa contínuo de conscientização em segurança e estabelecer um ciclo mensal de gestão de patches

**B)** Comprar um firewall de próxima geração, trocar de fornecedor de filtro de spam e aumentar os requisitos de complexidade de senha

**C)** Contratar um MSSP para monitorar logs, substituir o firewall e exigir treinamento anual de segurança

**D)** Desativar o encaminhamento externo de e-mails, exigir senhas de 16 caracteres e substituir o antivírus por uma alternativa gratuita

## GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

**Questão 1: Alternativa A — Implementar um programa disciplinado de gestão de vulnerabilidades e gestão de patches com ciclos de revisão mensais**

Correta: O patching é a técnica de mitigação fundamental. O ataque explorou uma falha conhecida e antiga para a qual já existia patch do fornecedor. Um programa consistente de gestão de patches garante que vulnerabilidades sejam remediadas antes que sejam exploradas. A opção B reage a assinaturas conhecidas, mas não corrige a vulnerabilidade em si. A opção C trata phishing, não exploração de VPN. A opção D limita danos, mas não impede o comprometimento inicial. O patching continua sendo a mitigação mais econômica e de maior ROI na estratégia de defesa em profundidade.

**Questão 2: Alternativa A — Implementar criptografia de disco completo (FDE) usando AES-256 em todos os dispositivos endpoint**

Correta: A criptografia de disco completo (FDE) protege os dados em repouso. Mesmo que o disco físico seja removido e montado em outro lugar, os dados permanecem ilegíveis sem a chave de criptografia. Esta é a única opção que protege os dados reais contra roubo físico ou extração de disco. A opção B limita o acesso dos usuários, mas não protege o conteúdo do disco. A opção C trata do comportamento de malware, não de roubo físico. A opção D exige conectividade de rede para execução e presume que o laptop está online; ela não protege dados já exfiltrados nem o disco se a limpeza falhar ou nunca ocorra.

**Questão 3: Alternativa A — Implementar um controle compensatório, como segmentação de rede e um IPS à frente dos sistemas legados**

Correta: Quando a mitigação ideal (substituição/patching) não é viável devido a restrições de negócio ou técnicas, um controle compensatório é a abordagem adequada. A segmentação de rede isola os sistemas legados, e um IPS fornece detecção/prevenção adicional contra explorações direcionadas a eles. Esta é a definição clássica de controle compensatório segundo a CompTIA Security+. A opção B paralisaria a produção. A opção C pode causar instabilidade em sistemas sem suporte e não é um controle real. A opção D é irrealista dada a restrição operacional de 18 meses e não é um controle de segurança, mas uma decisão de negócio.

**Questão 4: Alternativa A — Aplicar o Princípio do Menor Privilégio com acesso baseado em funções e elevação administrativa just-in-time**

Correta: O menor privilégio (PoLP) garante que cada conta tenha apenas as permissões necessárias para executar sua função. Um admin de domínio não deve ter acesso irrestrito a cada banco de dados; em vez disso, a administração em camadas e a elevação JIT delimitam rigorosamente os privilégios. Esta é uma mitigação fundamental segundo a CompTIA Security+. A opção B protege os dados em repouso, mas não controla o escopo de acesso. A opção C trata de vulnerabilidades, não de autorização. A opção D reduz o risco, mas não aborda o problema central de permissões excessivas.

**Questão 5: Alternativa A — Aplicar a regra de backup 3-2-1 com cópias imutáveis, air-gapped ou offline que não fiquem continuamente acessíveis**

Correta: A estratégia de backup falhou porque os backups estavam online e acessíveis ao ransomware. A regra 3-2-1 (3 cópias, 2 mídias, 1 offsite/offline) combinada com backups imutáveis ou air-gapped garante a recuperação mesmo quando os sistemas primários e os backups online são destruídos. A op��ão B trata de detecção, não de recuperação. A opção C pode ajudar, mas não é uma mitigação de backup e ignora a falha arquitetural. A opção D é importante, mas não aborda a falha do próprio desenho do backup.

**Questão 6: Alternativa A — Implementar um programa contínuo de capacitação de conscientização em segurança com campanhas simuladas de phishing e coaching just-in-time**

Correta: A capacitação de conscientização em segurança com simulações de phishing e coaching just-in-time visa diretamente o fator humano. Quando controles técnicos perdem 0,5% dos e-mails maliciosos, o usuário se torna a última linha de defesa. O treinamento reduz as taxas de cliques ao longo do tempo. A opção B paralisaria as operações. A opção C aborda detecção em endpoint, não a decisão humana de clicar. A opção D protege a autenticação, mas não impede que o usuário clique em um link malicioso que leva a um portal falso de captura de credenciais.

**Questão 7: Alternativa A — Endpoint Detection and Response (EDR) com análises comportamentais e telemetria de processos**

Correta: Soluções de EDR monitoram o comportamento de processos em endpoints, execução de scripts (PowerShell, WMI etc.), conexões de rede e atividade em memória, usando análises comportamentais e inteligência de ameaças para detectar ataques fileless que o AV baseado em assinatura não percebe. Elas também permitem resposta rápida (isolar host, encerrar processo). A opção B protege dados em repouso, mas não detecta ataques. A opção C encontra

vulnerabilidades, não入侵 ativas. A opção D filtra tráfego, mas não consegue detectar ataques em memória que usam protocolos/portas permitidos.

**Questão 8: Alternativa A — Defesa em Profundidade (DiD) com controles em camadas e sobrepostos**
Correta: Defesa em Profundidade é o princípio de sobrepor múltiplos controles de modo que a falha de qualquer um deles não resulte em comprometimento. O cenário descrito lista firewalls, EDR, allowlisting, backups criptografados, menor privilégio e treinamento — claramente uma abordagem em camadas. A opção B é um conceito de disponibilidade (alta disponibilidade). A opção C é um modelo arquitetônico específico que pressupõe ausência de confiança implícita e exige verificação contínua — distinto de DiD. A opção D é um princípio correlato, mas mais restrito, sobre desativar serviços/funções desnecessários.

**Questão 9: Alternativa A — Implementar criptografia na camada de aplicação dos dados do cartão antes de transmiti-los e armazená-los, usando chaves controladas pela organização**
Correta: A criptografia na camada de aplicação (às vezes chamada de criptografia client-side ou envelope) garante que os dados sejam criptografados antes de chegarem ao banco do fornecedor, usando chaves que a organização retém. Mesmo que o fornecedor seja violado, o ciphertext é inútil sem as chaves da organização. Esta é uma mitigação clássica de criptografia. A opção B é governança, não proteção de dados. A opção C trata de gestão de credenciais, não de confidencialidade dos dados. A opção D protege a sessão de rede, mas não os dados armazenados.

**Questão 10: Alternativa A — Implantar MFA em todas as contas de e-mail, aplicar menor privilégio com caixas postais baseadas em função, habilitar EDR em endpoints, implementar backups imutáveis offline, executar um programa contínuo de conscientização em segurança e estabelecer um ciclo mensal de gestão de patches**
Correta: Esta resposta cobre todas as camadas de mitigação: MFA + menor privilégio (controles de acesso), backups imutáveis (recuperação), EDR (detecção/resposta), treinamento de conscientização (pessoas) e gestão de patches (vulnerabilidades). Esta é a verdadeira defesa em profundidade. A opção B aborda apenas camadas de rede e autenticação de forma superficial. A opção C melhora o monitoramento, mas carece de prevenção e profundidade de recuperação. A opção D é um conjunto restrito de controles fracos que não aborda detecção, resposta, recuperação ou treinamento.